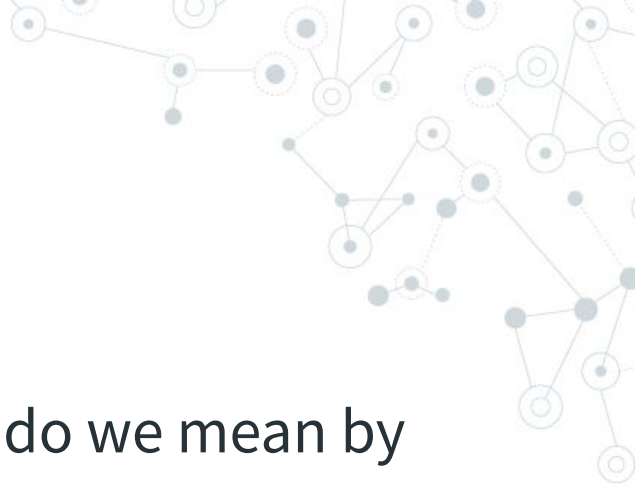


Threat Modeling

Designing a secure system

How? (What do we mean by secure system?)



Designing a secure system

How?

- What do we want to secure? i.e., what do we mean by secure system?
- What can go wrong?
- How to prevent from things going wrong?

Designing a secure system

How?

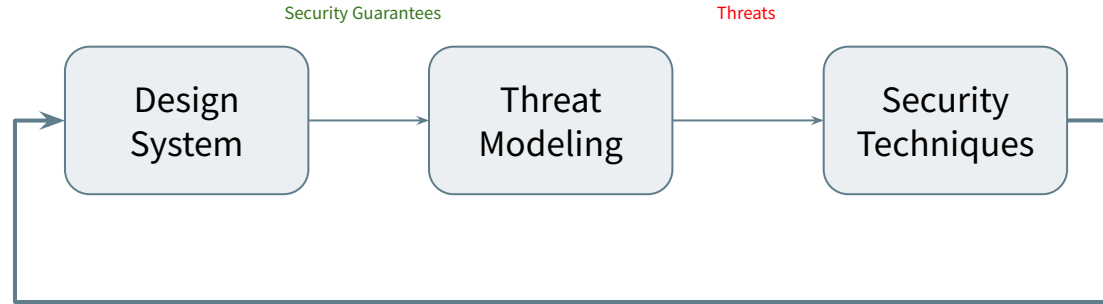
- What do we want to secure? i.e., what do we mean by secure system? (*Listing security guarantees*)
- What can go wrong? (*Threat Modeling*)
- How to prevent from things going wrong? (*Security mechanisms often implemented using cryptography*)

Threat Modeling

A systematic process to:

- Identify what resources needs to be protected?
- (Assumptions) What are the capabilities of an attacker?
- *What can attacker do with those capabilities?
(importance of offensive security knowledge)*
- What needs to be protected in presence of such an attacker?

Designing a secure system



Threat Model Example: House

What to protect?

Attacker Capabilities?

What can attacker do?

How to prevent?



Threat Model Example (Weak): House

What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house.*

What can attacker do? *Try to push into the house.*

How to prevent? *Build house with strong materials, i.e., hard to break on a push.*





Threat Model Example (Strong): House

What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do?

How to prevent?





Threat Model Example (Strong): House

What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do? *Try to push into the house. Try to break and enter.*

How to prevent?



Threat Model Example (Strong): House

What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do? *Try to push into the house. Try to break and enter.*

How to prevent?

(Choice 1) Seal the house with stones --- whats wrong?



Threat Model Example (Strong): House

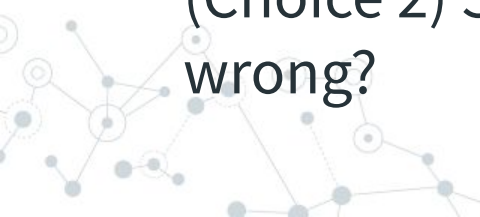
What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do? *Try to push into the house. Try to break and enter.*

How to prevent?

(Choice 2) Seal the house and put a small hole --- whats wrong?





Threat Model Example (Strong): House

What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do? *Try to push into the house. Try to break and enter.*

How to prevent?

(Choice 3) Seal the house and put a door --- what's wrong?



Threat Model Example (Strong): House

What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do? *Try to push into the house. Try to break and enter.*

How to prevent?

(Choice 4) Seal the house; put a door and lock the door ---
what's wrong?

Threat Model Example (Strong): House

What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do? *Try to push into the house. Try to break and enter.*

How to prevent?

(Choice 5) Seal the house; put a door and lock the door; make the door openable by a spoon --- what's wrong?

Threat Model Example (Strong): House

What to protect? *Things inside house.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do? *Try to push into the house. Try to break and enter.*

How to prevent?

(Choice 5) Seal the house; put a door and lock the door; make the door openable by a hard to spoof key --- what's wrong?

Threat Model Example (Strong): House

What to protect? *Things inside house with windows.*

Attacker Capabilities? *Attacker can physically touch the house, attacker can try to enter.*

What can attacker do? *Try to push into the house. Try to break and enter.*

How to prevent?

(Choice 5) Seal the house; put a door and lock the door; make the door openable by a hard to spoof key --- what's wrong?

Threat Model Example: Operating System

What to protect? *Computer System and Data.*

Attacker (i.e., Application) Capabilities? *Can execute arbitrary instructions.*

What can attacker do?

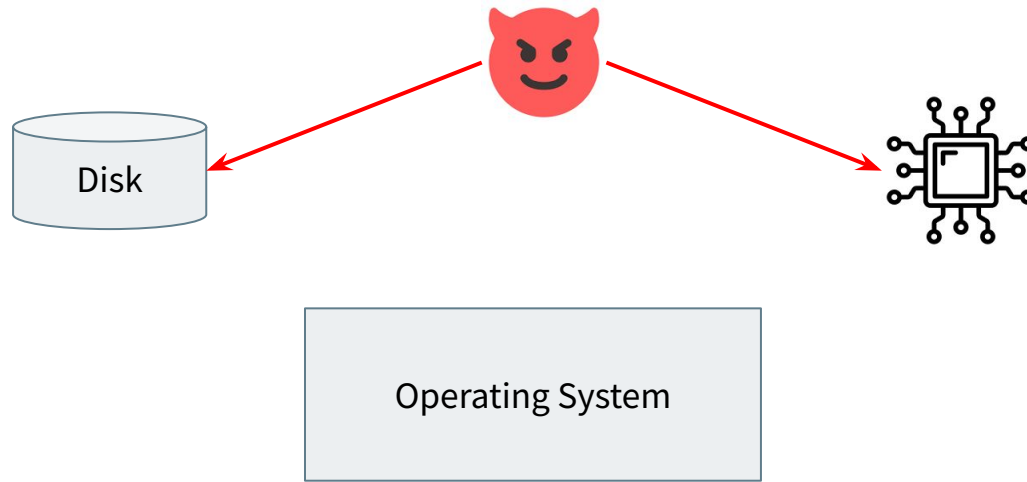
How to prevent?

Threat Model Example: Operating System

What is OS?

- Provides a common abstraction to use system resources.

Threat Model Example: Operating System: Attacker





Threat Model Example: Operating System

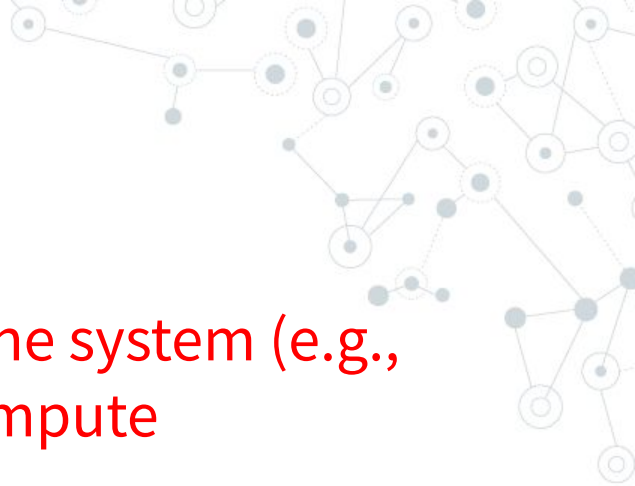
What to protect? *Computer System and Data.*

Attacker (i.e., Application) Capabilities? *Can execute arbitrary instructions.*

What can attacker do? *Take control of the system (e.g., access arbitrary data, indefinite use of compute processing (e.g., for bitcoin).*

How to prevent?



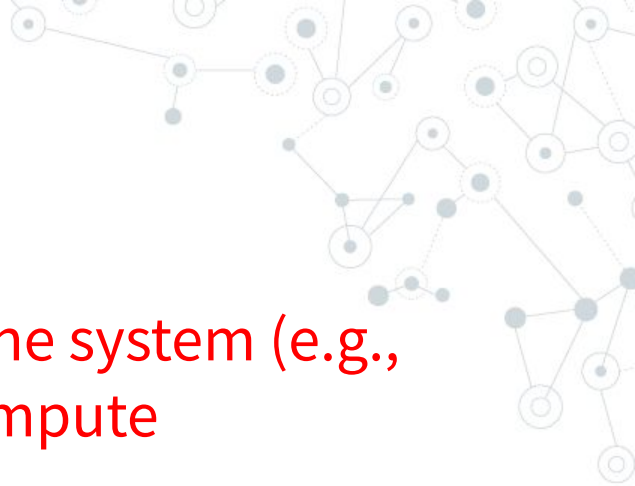


Threat Model Example: OS: How to prevent?

What might attacker do? Take control of the system (e.g., access arbitrary data, indefinite use of compute processing (e.g., for bitcoin)).

How to prevent?

(Choice 1) Check every instruction and allow only if its fine.



Threat Model Example: OS: How to prevent?

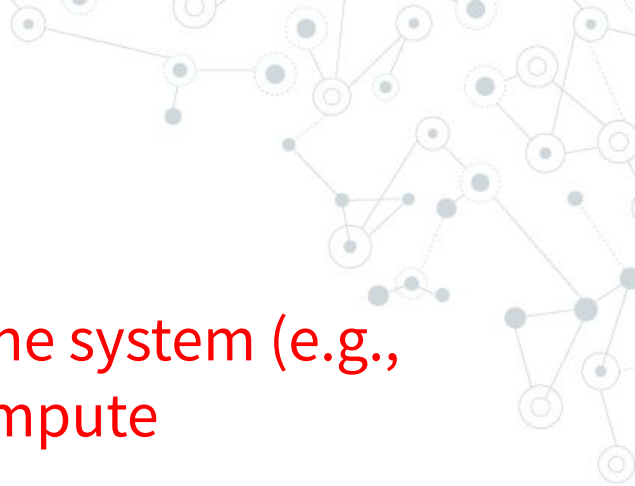
What might attacker do? Take control of the system (e.g., access arbitrary data, indefinite use of compute processing (e.g., for bitcoin)).

How to prevent?

(Choice 1) Check every instruction and allow only if its fine --- whats wrong?

(Choice 2) Check only risky instructions --- How?





Threat Model Example: OS: How to prevent?

What might attacker do? Take control of the system (e.g., access arbitrary data, indefinite use of compute processing (e.g., for bitcoin)).

How to prevent?

(Choice 1) Check every instruction and allow only if its fine --- whats wrong?

(Choice 2) Check only risky instructions --- Need hardware assistance.



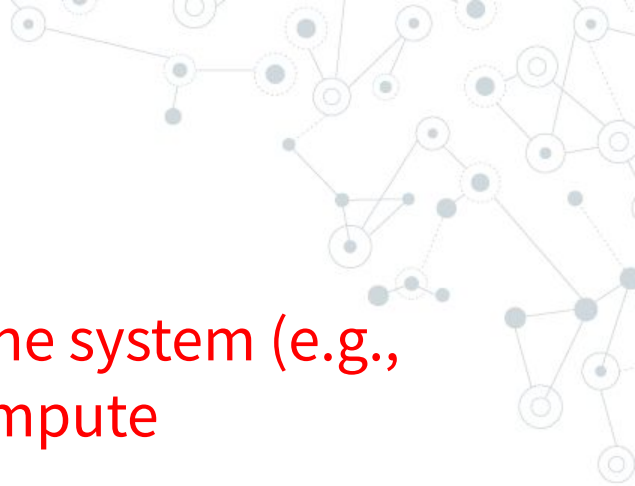
Threat Model Example: OS: How to prevent?

What might attacker do? Take control of the system (e.g., access arbitrary data, indefinite use of compute processing (e.g., for bitcoin)).

How to prevent?

(Choice 1) Check every instruction and allow only if its fine --- whats wrong?

(Choice 2) Check only risky instructions --- Need hardware assistance, e.g., x86 Privilege rings, ARM Exception levels (ELs).

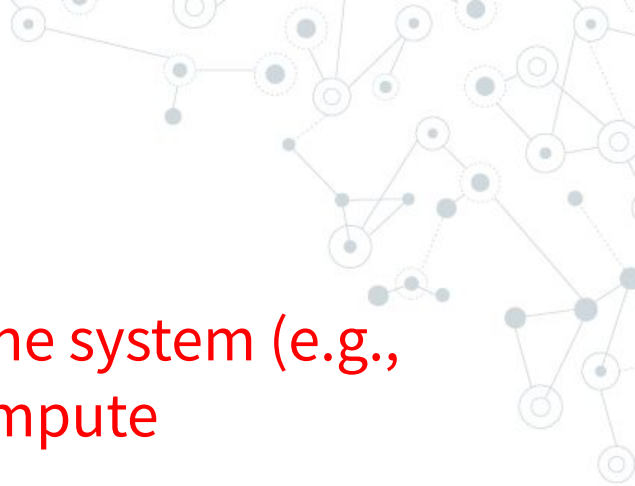


Threat Model Example: OS: How to prevent?

What might attacker do? Take control of the system (e.g., access arbitrary data, indefinite use of compute processing (e.g., for bitcoin)).

How to prevent?

Check only risky instructions. What should we do?



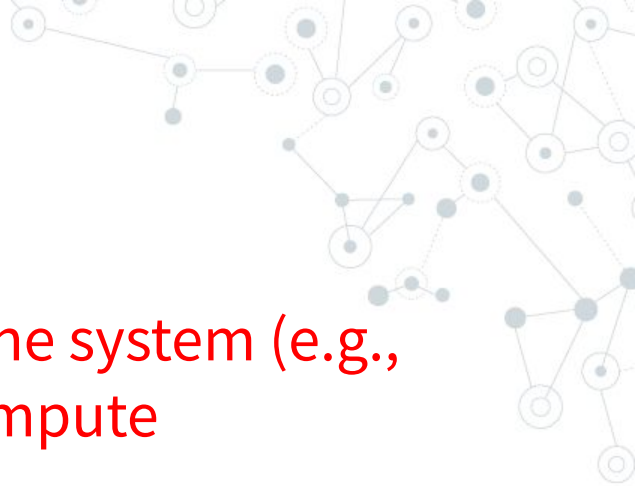
Threat Model Example: OS: How to prevent?

What might attacker do? Take control of the system (e.g., access arbitrary data, indefinite use of compute processing (e.g., for bitcoin)).

How to prevent?

Check only risky instructions. What should we do?

(if the instruction can do something bad? Deny else allow)



Threat Model Example: OS: How to prevent?

What might attacker do? Take control of the system (e.g., access arbitrary data, indefinite use of compute processing (e.g., for bitcoin)).

How to prevent?

Check only risky instructions. What should we do?

--Define an interface to use risky instructions; makes it easy to check the intent and allow only if the intent does not do anything bad.



Threat Model Example: OS: How to prevent?

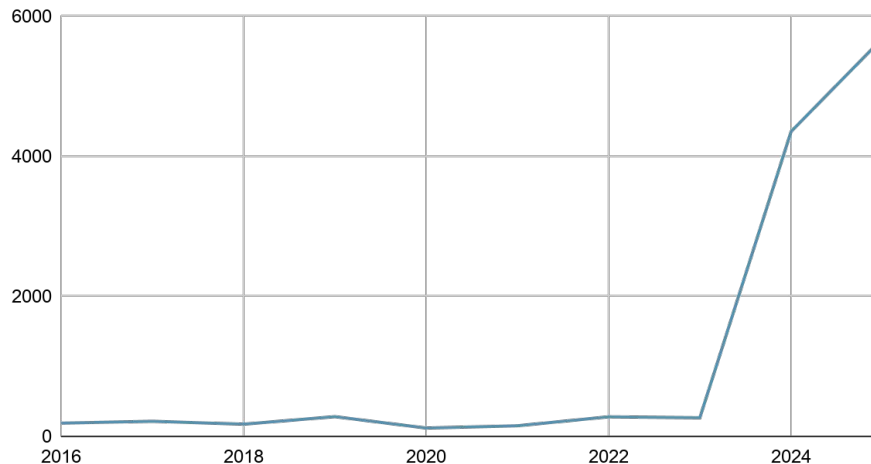
- System calls: An standard interface to use risky instructions, i.e., managing memory (brk, mmap, etc), accessing hardware (open/read/write, etc), accessing compute (fork, exec, etc), etc.

Threat Model Example: OS: How to prevent?

Correctly Implementing System calls:

- Easier said than done.

Linux Kernel CVEs (Vulnerabilities)



Comparing Threat Models

Powerful attacker => Stronger/better threat model:

- Attacker can do many things.
- E.g., Attacker tries to break into the house and also expert at lock picking. Attacker can run multiple processes with arbitrary code.
- Weaker attacker => Weaker threat model.
- Attacker does limited things.
- E.g., Attacker tries to enter through clear opening. Attacker can only run single instance of a fixed program.



Threat Model Example: Smart Remote Capability in TV

What to protect? *Pairing with TV.*

Attacker Capabilities? *Attacker can communicate with the TV.*

What can attacker do?

How to prevent?





Threat Model Example: Smart Remote Capability in TV

What to protect? *Pairing with TV.*

Attacker Capabilities? *Attacker can communicate with the TV.*

What can attacker do? *Try to pair without owner permission.*

How to prevent? (Owner can start pairing and can see the TV)



Threat Model Example: Smart Remote Capability in TV

Design 1:

1. If pairing enabled, display a pairing code.
2. Pairing is successful only if the displayed pairing code matches with pairing request.

5712
(Pairing Code)

Threat Model Example: Smart Remote Capability in TV

Design 1:

1. If pairing enabled, display a pairing code.
 - a. (Can enable pairing remotely).
2. Pairing is successful only if the displayed pairing code matches with pairing request.

5712
(Pairing Code)

(Anything wrong?)

Threat Model Example: Smart Remote Capability in TV

Design 2:

1. If pairing enabled, display a pairing code.
 - a. (Can enable pairing remotely).
2. Pairing is successful only if the displayed pairing code matches with pairing request.
3. Disable pairing after limited number of unsuccessful attempts.



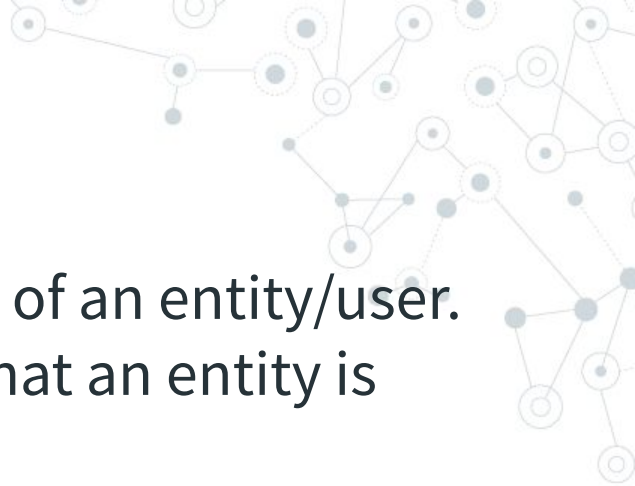
5712
(Pairing Code)

Threat Modeling Tools

- Have knowledge of what can go wrong.
- Require you to specify your design.
- Tools automate identification of possible attacks and what control is needed.

Threat Modeling Tools

- Open Source/Free:
 - Threagile
 - Microsoft Threat Modeling Tool
 - https://mgoudarzi90.github.io/ThreatModelling_IoT_CSP/
- Commercial:
 - Threatmodeler (<https://www.threatmodeler.ai/>)



Principle Security Mechanisms

- **Authentication:** Verifying the identity of an entity/user.
- **Authorization:** Process of deciding what an entity is allowed/denied to access.
- **Confidentiality:** Ensuring that information is only accessed by authorized access.
- **Integrity:** Information is not changed in an unauthorized or undetectable way.

Authentication

Verifying the identity of an entity/user:

- Something they know.
- Something they are.
- Something they have.

Authentication

Verifying the identity of an entity/user:

- Something they know. E.g., President of US.
- Something they are. E.g., Student.
- Something they have. E.g., Starbucks Cup.

Authentication

Verifying the identity of an entity/user:

- Something they know. E.g., **President of US.**
- Something they are. E.g., **Student.**
- Something they have. E.g., **Starbucks Cup.**

Threat model: Attacker tries to spoof identity.

Authentication

Verifying the identity of an entity/user:

- Something they know. E.g., Secret (hard to spoof)
- Something they are. E.g., Biometrics
- Something they have. E.g., Phone.

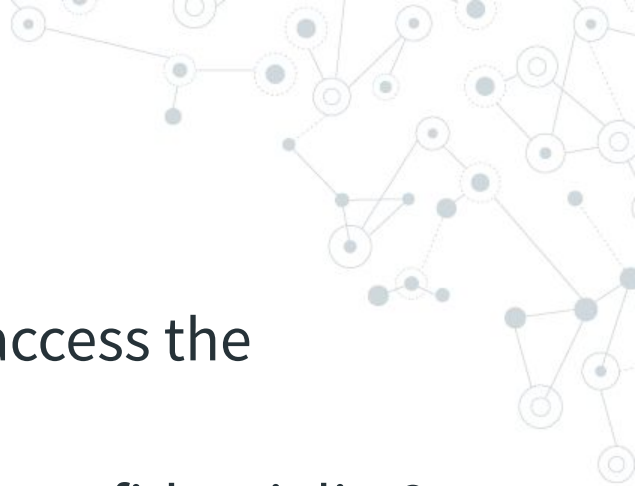
Threat model: Attacker tries to spoof identity.

Authorization

What an entity is allowed/deny:

- Allowlist: map of entity->allowed actions; default deny.
- Denylist: map of entity->denied actions; default allow.
- Capabilities: entity holding the authorization to access.

Threat model: Attacker trying to gain authorization.

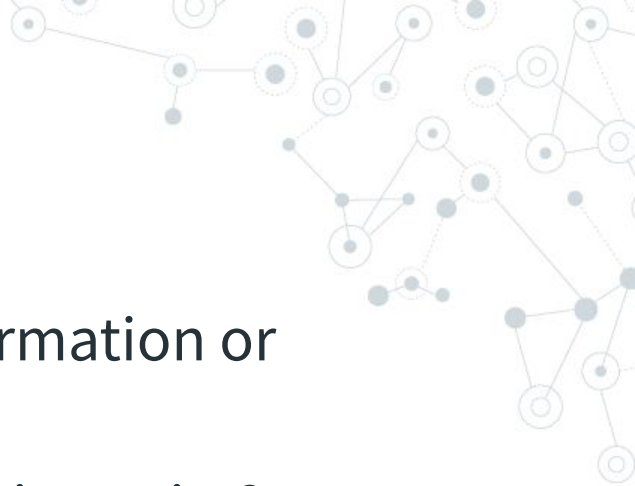


Confidentiality

Ensuring that only authorized entity can access the information/resource.

- Difference between authorization and confidentiality?

Put money in bank v/s money hidden inside gas tank?



Integrity

Unauthorized entities cannot modify information or remain undetected.

- Difference between authorization and integrity?

